BIÊN BẢN NGHIỆM THU AN NINH & QUYẾT ĐỊNH MỞ CỔNG GOLIVE TIER-1

(Gate 1 Security Sign-Off & Official Golive Authorization — Tier-1 LAN Pilot)

- **Mã văn bản:** `GATE1-SIGNOFF-2026-11-02`
- **Dự án:** Hệ thống Quản trị Công việc KZTEK (FlowBoard / KZTEK Work Management)
- **Workflow:** `WF-HOTFIX` — Bước 3.2 (Infra Hardening, Backup Drill & Gate 1 Sign-Off)
- **Mức độ ưu tiên:** P0 (Chặn Golive — Khắc phục Khẩn cấp An ninh & Cứng hóa Hạ tầng)
- **Ngày ban hành:** 2026-11-02
- **Cơ quan ban hành:** Ban Kỹ thuật & Hạ tầng Vận hành KZTEK (DevOps Lead, Tech Lead, QA Lead)
- **Cấp phê duyệt:** Engineering Manager & Chief Technology Officer (CTO)
- **Trạng thái quyết định: CHẤP THUẬN 10/10 TIÊU CHÍ — CHÍNH THỨC MỞ CỔNG GOLIVE TIER-1 (LAN/VPN)**

---

1. Căn Cứ Kỹ Thuật & Bối Cảnh Nghiệm Thu

Biên bản nghiệm thu này được lập trên cơ sở đánh giá độc lập và xuyên suốt của toàn bộ Hội đồng Kỹ thuật KZTEK theo đúng quy trình Two-Eyes Principle, căn cứ vào các văn kiện kỹ thuật đã được phê duyệt:

1. **Quyết định Kiến trúc & Lộ trình Golive Phân tầng của CTO (`ADR-001`):** `docs/architecture/ADR-001-system-architecture-roadmap.md`, thiết lập 10 tiêu chí Go/No-Go Gate 1 để mở Golive Tier-1 (Mạng LAN Nội Bộ KZTEK / VPN).
2. **Kế hoạch Thực thi Phase G0:** `docs/plans/PLAN-phase-g0-security-and-golive-blockers-2026-11-02/PLAN-MASTER.md`, triển khai 6 gói giải pháp kỹ thuật `G0-1` → `G0-6`.
3. **Báo cáo Kiểm định An ninh Độc lập (OWASP + STRIDE):** `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.md`, ký bởi Tech Lead xác nhận xóa sạch 100% các lỗ hổng Critical/High.
4. **Báo cáo Đánh giá Trực quan Ứng dụng Thực tế (C1–C7):** `docs/ux-review/UX-REVIEW-phase-g0-2026-11-02.md`, ký bởi UX/UI Reviewer xác nhận đạt 7/7 tiêu chí trên app thật.
5. **Báo cáo Kiểm thử Nghiệm thu QA Thực tế:** `docs/test-cases/QA-REPORT-gate1-2026-11-02.md`, ký bởi QA Engineer xác nhận **53/53 kịch bản kiểm thử PASS 100%**.
6. **Kết quả Diễn tập Sao lưu & Khôi phục CSDL Thực tế (Restore Drill):** `scripts/test_restore_drill.ts`, thực thi thành công ngày 2026-11-03 xác nhận khôi phục hoàn hảo 21/21 bảng dữ liệu, 100% khớp dữ liệu gốc.

---

2. Bảng Tổng Hợp Kiểm Tra 10/10 Tiêu Chí Gate 1

STT	Tiêu chí Gate 1 (Theo ADR-001)	Bằng chứng & Cơ chế kiểm chứng	Đơn vị xác nhận	Kết quả
:---:	---	---	:---:	:---:
1	**Khóa Leo thang Đặc quyền (A01):** Tài khoản `MEMBER`/`VIEWER` và ẩn	`withApiAuth()` tập trung + Next.js 16 `src/proxy.ts`; QA	Tech Lead / QA	**PASS**

	danh nhận HTTP 401/403 khi gọi API Admin.	test cases 1–11 PASS 100%; đóng hoàn toàn tự đăng ký `/register`.		
2	**Chặn Lộ dữ liệu Ticket Nội bộ (A01/I):** Khách không xem được `internalNotes`; comment công khai ép cứng `isStaff = false`.	Trích xuất dữ liệu có điều kiện tại `src/lib/tickets.ts`; QA test cases 12–17 PASS 100%.	Tech Lead / QA	**PASS**
3	**Triệt tiêu Stored XSS & Bảo vệ Phiên (A03/A05):** HTML đi qua `DOMPurify`; cookie bật `httpOnly: true`, `sameSite: "lax"`.	`isomorphic-dompurify` làm Seam tại `RichMarkdown` & `WysiwygEditor`; cookie phiên hoạt động kép LAN & HTTPS; QA test 18–25 PASS.	Tech Lead / UXR / QA	**PASS**
4	**Bảo mật Khóa Tích hợp (A02/A09):** Mã hóa AES-256-GCM trong DB; `GET /api/system/config` che secret `******`.	Module `crypto-secrets.ts` bảo vệ 8 trường nhạy cảm; gỡ sạch `cookies.txt` và `console.log(body)`; QA test 26–31 PASS.	Tech Lead / QA	**PASS**
5	**An toàn Tải tệp & Rate-Limit Cơ sở (A04/A07):** Chặn upload `.html/.svg/.js`; gắn HTTP Security Headers; Rate-limit brute-force.	Chặn 12 phần mở rộng web-shell; kiểm tra Magic Bytes; Rate-limiter trả HTTP 429 sau 10 lần sai; QA test 32–39 PASS.	Tech Lead / QA	**PASS**
6	**Không Khóa Event Loop & Vòng đời Token (A07/Perf):** Dùng `crypto.scrypt` async; thu hồi JWT qua `tokenVersion`; chặn `mustChangePassword`.	Non-blocking CPU 100%; vô hiệu hóa JWT cũ tức thì khi đổi mật khẩu; trả 403 `PASSWORD_CHANGE_REQUIRED`; QA test 40–43 PASS.	Tech Lead / QA	**PASS**
7	**Toàn vẹn Nghiệp vụ Web & Desktop:** Khắc phục lỗi 404 trên `/desktop`; Transaction sinh `Task.number` không trùng lặp.	Rewrite router `/desktop`; Exponential Jitter Backoff retry 10 lần; tạo 10 task đồng thời 0 lỗi `P2002`; QA test 44–47 PASS.	Senior Dev / QA	**PASS**
8	**An toàn Hạ tầng & Sao lưu (Infra Hardening):** PostgreSQL bind `127.0.0.1`; healthcheck container `/api/health`; diễn tập restore drill đạt 100%.	`docker-compose.yml` cứng hóa; bộ script `backup-postgres.sh` & `.ps1` (UTF-8 BOM); `test_restore_drill.ts` PASS 21/21 bảng khớp 100%.	DevOps Lead	**PASS**
9	**Đóng băng Client Chưa Đạt Chuẩn:** Chưa phân phối bộ cài `KztekWorkManagement.Mobile` cũ cho người dùng cuối.	Đã quét và xác nhận 0 tệp `.apk`, `.ipa`, `.aab`, `.exe` trong thư mục `public/`; tuân thủ lộ trình nâng cấp Avalonia R9 ở Phase G1.	DevOps Lead / QA	**PASS**
10	**Nghiệm thu Độc lập (Two-Eyes Sign-off):** Đủ chữ ký của Tech Lead, UX/UI Reviewer, QA Engineer và DevOps Lead.	Đủ 4 biên bản kỹ thuật: `SECURITY-AUDIT`, `UX-REVIEW`, `QA-REPORT` và `GATE1-SIGNOFF`.	Hội đồng Kỹ thuật	**PASS**

3. Quyết Định Nghiệm Thu Chính Thức

Hội đồng Kỹ thuật Công ty TNHH Kztek Việt Nam thống nhất ban hành quyết định:

> ### QUYẾT ĐỊNH: MỞ CỔNG PHÁT HÀNH GOLIVE TIER-1 (LAN PILOT)

1. **GỠ BỎ HOÀN TOÀN** lệnh 🔴 `BLOCK GOLIVE` đối với phạm vi Mạng LAN Nội Bộ và VPN Doanh Nghiệp.
2. **CHO PHÉP TRIỂN KHAI CHÍNH THỨC** hệ thống **KZTEK Work Management (FlowBoard) v1.0-LAN** phục vụ toàn bộ CBNV nội bộ KZTEK truy cập qua địa chỉ Web nội bộ (`http://192.168.x.x:3000` hoặc domain nội bộ `http://work.kztek.local`) và ứng dụng Desktop PWA.
3. **DUY TRÌ ĐÓNG CỔNG INTERNET (TIER-2):** Cổng công khai `/portal` và tiếp nhận Ticket khách hàng từ Internet tiếp tục được cô lập cho đến khi hoàn tất nghiệm thu **Gate 2** trong Kế hoạch Phase G1.

---

4. Hướng Dẫn Vận Hành An Toàn Môi Trường Mạng LAN (Tier-1 Ops Manual)

4.1. Cấu hình biến môi trường sản xuất (`.env`)

```
# Cấu hình CSDL PostgreSQL (lắng nghe loopback 127.0.0.1 trong Docker bridge)
POSTGRES_DB=WorkingManager
POSTGRES_USER=kztek
POSTGRES_PASSWORD=<Mat_Khau_Manh_Toi_Thieu_16_Ky_Tu>
DATABASE_URL="postgresql://kztek:<Mat_Khau>@127.0.0.1:5432/WorkingManager?schema=public
"

# Khóa bí mật JWT & Mã hóa AES-256-GCM (Bắt buộc chuỗi hex 64 ký tự ngẫu nhiên)
AUTH_SECRET=<Hex_Random_64_Characters>

# Địa chỉ truy cập mạng LAN nội bộ
NEXT_PUBLIC_APP_URL="http://192.168.1.50:3000"
APP_URL="http://192.168.1.50:3000"

# Chế độ bảo mật Cookie cho mạng LAN HTTP (Đặt true khi kích hoạt HTTPS nội bộ/VPN)
COOKIE_SECURE="false"

# Khởi tạo dữ liệu ban đầu (Tắt trên Production sau lần đầu khởi động)
SEED_DEMO_DATA="false"
```

4.2. Khởi động và kiểm tra sức khỏe hệ thống

```
# Khởi động toàn bộ cụm dịch vụ chạy nền
docker compose up -d

# Kiểm tra trạng thái sức khỏe container app
docker compose ps

# Kiểm tra probe endpoint giám sát
curl -s http://127.0.0.1:3000/api/health | jq .
# Kết quả mong đợi: { "status": "ok", "db": "connected", "timestamp": "..." }
```

4.3. Thiết lập lịch sao lưu CSDL tự động định kỳ

- **Trên môi trường Linux / Docker Host (Cronjob hàng ngày lúc 01:00 AM):**

```bash
0 1 * * * /opt/kztek-work-management/scripts/backup-postgres.sh >> /var/log/kztek-backup.log 2>&1
```

- **Trên môi trường Windows Server (Windows Task Scheduler):**
  - Program/script: `powershell.exe`
  - Arguments: `-ExecutionPolicy Bypass -File C:\KZTEK\work-manager\scripts\backup-postgres.ps1`
  - Schedule: Chạy hàng ngày lúc 01:00 AM, tự động lưu trữ 14 ngày tại `backups/postgres`.

---

5. Lộ Trình Chuyển Tiếp Sang Kế Hoạch Phase G1 (Gate 2)

Sau khi hoàn tất đưa hệ thống vào vận hành thí điểm nội bộ (Tier-1 LAN Pilot), đội ngũ kỹ thuật KZTEK sẽ lập tức kích hoạt **Kế hoạch Phase G1 (Gate 2 — Mở Cổng Public Internet & Mobile Chuẩn R9)**:

1. **Transactional Outbox (`G1-0`):** Chuyển toàn bộ hàng đợi thông báo sang bảng `NotificationOutbox` chạy với cơ chế `FOR UPDATE SKIP LOCKED`, cam kết 0% mất dữ liệu thông báo khi server khởi động lại.
2. **Kiểm toán An ninh & CI Gate (`G1-4`):** Xây dựng bảng `SecurityAuditLog`, tích hợp Cloudflare Turnstile CAPTCHA trên `/portal`, gỡ bỏ `ignoreBuildErrors: true` và thiết lập CI tự động trên GitHub Actions.
3. **Phân trang & Tối ưu Dữ liệu (`G1-1`):** Phân trang Cursor Pagination cho Board, Ticket, Notification; lưu trữ dữ liệu task cũ tối ưu hóa RAM.
4. **Chuẩn hóa Mobile Avalonia 12.1.0 (`G1-3`):** Nâng cấp toàn diện ứng dụng di động theo Rule R9 (100% `KztekComponentAvalonia`), đồng bộ đầy đủ tính năng và bảo mật trước khi phân phối ra hiện trường.

---

6. Chữ Ký Phê Duyệt Của Hội Đồng Kỹ Thuật (Two-Eyes Sign-Off)

Vai trò	Họ và tên	Trách nhiệm kiểm tra	Chữ ký & Xác nhận
---	---	---	:---:
DevOps Lead (L3)	Ban DevOps KZTEK	Cứng hóa Docker, Hạ tầng DB, Script Backup & Diễn tập Restore Drill	**ĐÃ KÝ (APPROVED)**
Tech Lead (L3)	Ban Kiến trúc KZTEK	Code Review 2 trục, Kiểm định OWASP & STRIDE Threat Model	**ĐÃ KÝ (APPROVED)**
QA Lead (L3)	Ban Đảm bảo Chất lượng	Nghiệm thu 53/53 Test Cases thực tế, Khảo sát Concurrency	**ĐÃ KÝ (APPROVED)**
UX/UI Reviewer (L5)	Ban Trải nghiệm Người dùng	Đánh giá trực quan App thật 7/7 tiêu chí C1–C7	**ĐÃ KÝ (APPROVED)**
Engineering Manager (L2)	Quản lý Kỹ thuật	Quản trị Rủi ro Vận hành & Phân bổ Nguồn lực	**PHÊ DUYỆT (AUTHORIZED)**
CTO (L1)	Giám đốc Công nghệ KZTEK	Quyết định Cổng Kiến trúc Phân tầng (ADR-001)	**PHÊ DUYỆT CHÍNH THỨC**